Android 隐私检测系统
Lab4-2 / Lab4-3 动态验证实验汇报

Frida 三层 Hook • mitm 网络主轨 • Lab4-2/3 十五 App 实验

李禹江，张博涵，蒋兴宇

我的刀盾队

2026-06-12

目录

1. 实验背景与范围
2. 单次动态验证与实验管线
3. Frida 动态验证架构
4. Frida 工程卡点
5. mitm 网络主轨
6. 实验结果与截图
7. 手段可用性总览
8. 总结与后续

汇报范围

- **Frida 动态验证**：一趟取证业务流程、三层 Hook（IMEI / OkHttp / PAPI）、Reactor 串行化。
- **Frida 工程卡点**：Spawn 问题、三类典型故障：防注入、找不到进程、连接断开。
- **mitm 网络主轨**：替代 rekit OkHttp Hook，支撑 Lab4-2/3 污点与同意权比对。
- **LLM 辅助路径展开、支付宝 H5 特例、15 App 实验结果**。

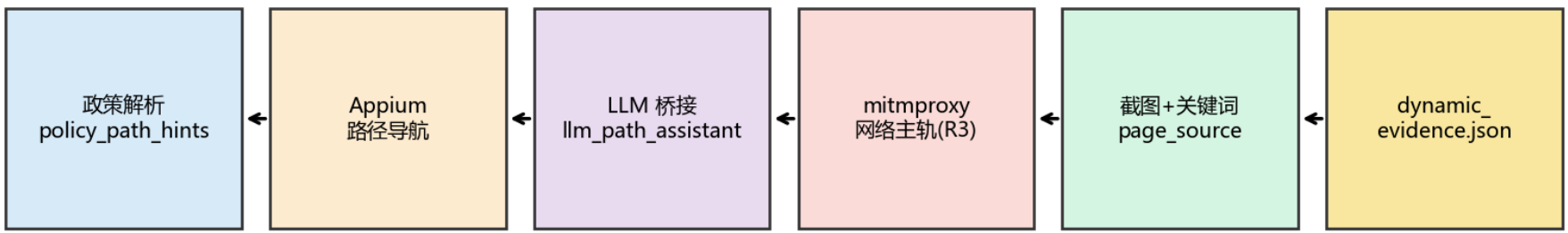
本批样本 App

实验	App & 批量状态
Lab4-2 同意权	**15/15** pass 3；7 款 App 有关后仍传的问题
Lab4-3 访问权	**9/15** 有报告；6 款待副本导出

Stage3 单次动态验证流程

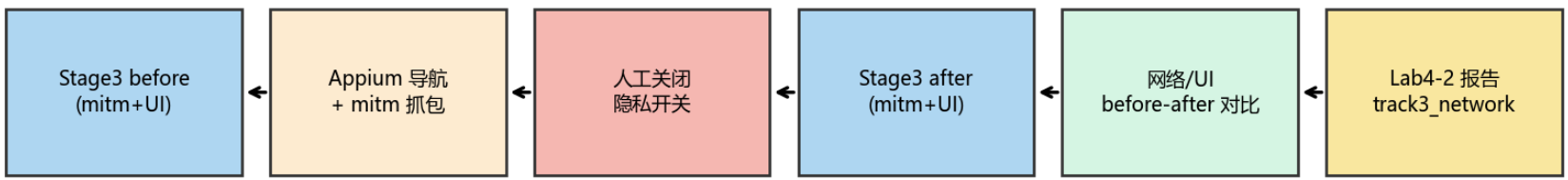
1. **解析路径**：隐私政策 → `navigation_paths[]`（点击序列）。
2. **并行取证**：**mitm** 代理抓包 | **Frida** 注入 Hook | **Appium** 真机导航。
3. **UI 点击**：按路径逐 token 点击；失败则滚动 → 侧栏 → 桥接 → LLM 兜底。
4. **证据落盘**：`dynamic_evidence.json`、`mitm_flows.json`、`network_evidence.json`。

Stage3 数据流


政策解析
policy_path_hints
Appium
路径导航
LLM 桥接
llm_path_assistant
mitmproxy
网络主轨(R3)
截图+关键词
page_source
dynamic_
evidence.json

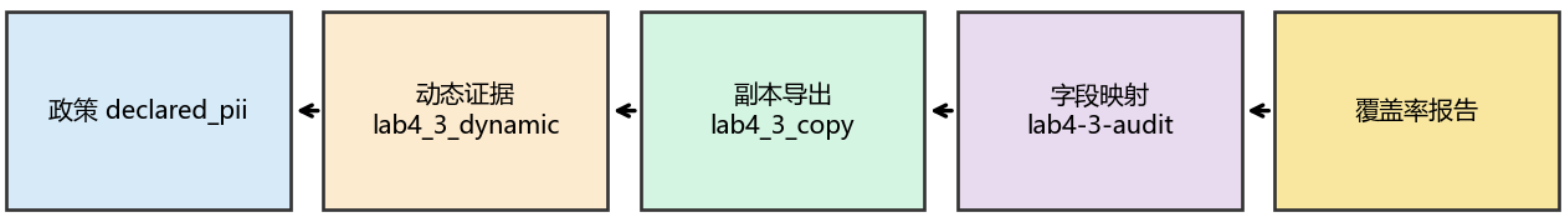
Lab4-2 实验管线（同意权 • mitm-primary）

1. **Before**：动态验证 + mitmproxy
2. 真机操作：关闭隐私相关开关（或切换基本版等）
3. **After**：同上
4. **主判定**：比对关开关前后 mitm 流量中的 **Tracker** 与 **PII 网络字段**——关后仍传则同意权未生效。
5. **辅助**：比对 Appium 页面 **关键词**与 **导航点击**——关后 UI 是否仍暴露「个性化」等信号。

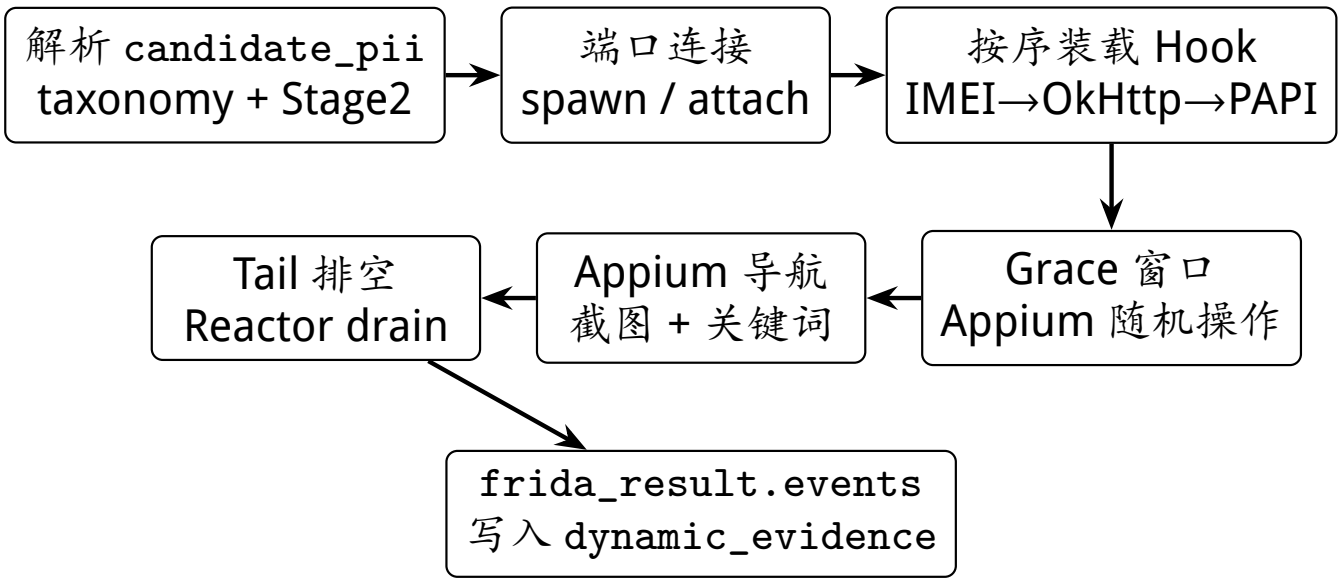


Lab4-3 实验管线（访问权）

1. **三份输入**：隐私政策（声明了哪些 PII）、动态取证（Frida + mitm）、用户导出的个人信息副本。
2. **运行时汇总**：合并 Frida 与 mitm 观测 → 「实际采集/传输了哪些 PII」。
3. **副本比对**：运行时字段是否在副本中可查；副本字段是否与政策声明一致（taxonomy 别名匹配 + 人工审核）。



Frida 一趟动态验证业务流程



三层 Hook 设计与职责

Hook	脚本	职责	特点
IMEI_HOOK	`hook_imei.js`	拦截 TelephonyManager 等设备标识符 API	**完全静态**：类/方法硬编码，不依赖混淆发现
OKHTTP_HOOK	`hook_network_okhttp.js`	出站 HTTP 请求体/URL 污点；开/关权限前后比对	源自 **rekit**；混淆感知枚举 `okhttp3.*` 指纹
PAPI_HOOK	`hook_papi.js`	`api_targets` 动态决定监测面	`pii_type` 分类；`stack_summary` 调用栈节选

- **装载顺序**：注册表 Hook（IMEI）→ OkHttp → RPC 装载 PAPI（`installhooks`）
- **Lab4-2**：OkHttp 事件 + mitm 网络字段，开关前后污点对比
- **Lab4-3**：Frida 观测 ∪ mitm `pii_key_hits`，判断是否离设备上传

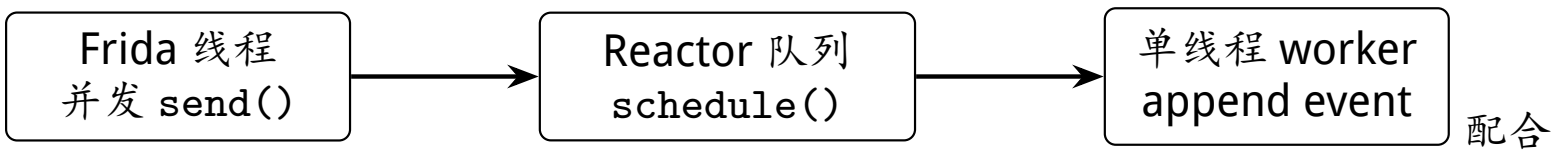
Reactor：Frida 回调串行化

问题

- Frida 在独立线程投递 `script.on('message')`
- 多 Hook 并行回调直接写共享 `events[]` → 竞态、丢事件
- 静态 Hook（IMEI）与动态 PAPI 同时触发时尤甚

方案

- `frida_reactor.Reactor`：单 worker 线程 + 延迟队列
- 所有 `on_message` 仅 `reactor.schedule(fn)`
- `stop(drain_timeout=3s)`：停止前**排空**待处理回调



配合 `wrap_hook_script`：`__frida_java_install` 等待 `Java.available` 后再执行 Hook 体，避免 ART 未就绪时静态脚本失效。

Spawn vs Attach：核心困局

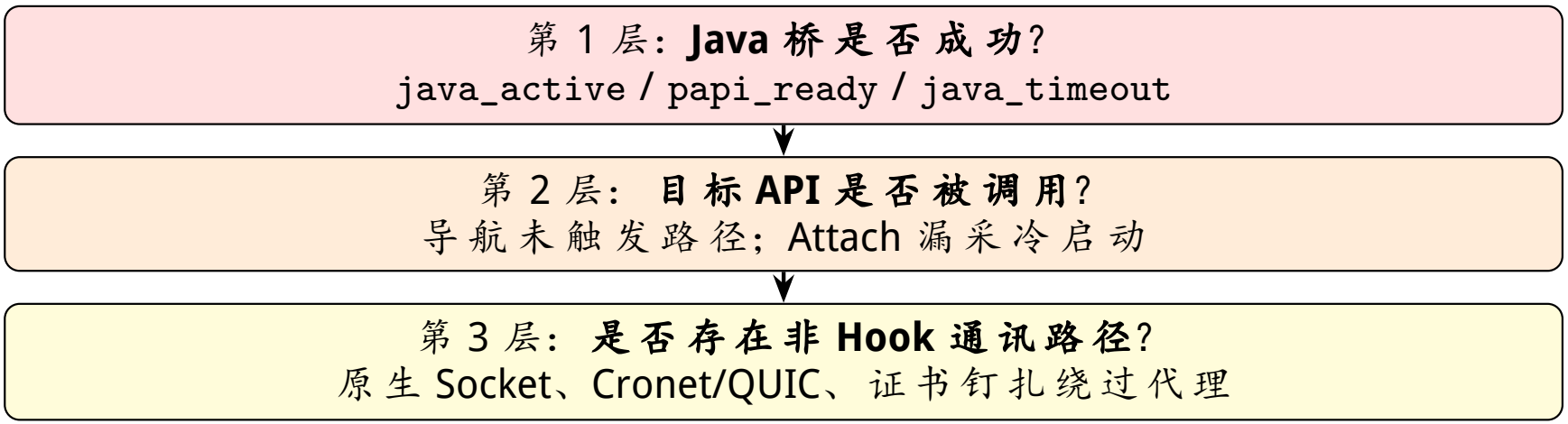
模式	优势	本实验现状
Spawn（冷启动暂停注入）	可在 resume 前装完全部 Hook；可抓冷启动标识符读取	**多数 App 不可用**：反注入、spawn 失败、MuMu 进程管理异常
Attach（附着已运行进程）	绕开部分 spawn 限制；与 Appium 共存较稳	**默认 fallback；天然漏采**：注入前已发生的 API 调用无法回溯

- 策略：`spawn_fallback_attach=true`；Attach 后 **Grace**（默认 30s）+ **Tail**（60s）延长观测窗
- Appium 随机滑动/点击 + 网络发包，辅助在 MuMu 多进程中**锁定目标 PID**

三类典型注入故障

症状	机理	代表 App
java_not_ready / java_timeout	ART 未就绪或强防护阻塞 Java.perform；Hook 脚本无法进入 Java 桥	**支付宝**（强反 Frida）
No such process	进程在 attach/probe 窗口内被系统或 App 瞬杀；PID 失效	**东方财富**、58 同城
MuMu **多进程 PID 混淆**	包名对应多个进程，attach 到错误进程（WebView/推送子进程）	智联招聘、小红书等

采集失败的三层漏斗



- 任一层失败 → Frida 侧 `frida_runtime_events` 偏低或为空
- 本批 5 月主实验：6/9 App 的 Frida runtime 为 0；**mitm 网络轨**由此成为 Lab4-2/3 主证据
- PAPI 仍保留：对 tier1 App（小荷健康、世纪佳缘）补充 API 级 `stack_summary`

为何引入 mitm?

- **OkHttp Hook 的局限**（即 rekit `okhttp.js` 路线）
  - 仅覆盖 Java 层 OkHttp 栈；Native/Cronet/自研协议不可见
  - Attach 漏采 + 混淆后类发现仍可能失败；与 Appium 同进程竞争
  - Frida 不稳定时，Lab4-2 无法做可靠的开关前后污点对比
- **mitm 的定位：进程无关**的全局 HTTP(S) 旁路抓包
  - 替代 rekit OkHttp Hook 作为 Lab4-2/3 的**核心网络模块**
  - Frida 降为辅助：PAPI 补 API 调用栈，IMEI Hook 补设备标识读取

mitm 抓包与分析流程

1. **设代理抓包**：MuMu 经 ADB 走 mitm 代理，Appium 导航期间持续记录 HTTP 流量。
2. **离线分析**：扫描请求 URL/Body 中的 **PII 字段**与 **Tracker 域名**（Umeng、Bugly、百度广告等）。
3. **证据落盘**：输出流量条数、PII 命中、Tracker 命中，写入网络证据 JSON。
4. **收尾**：清除代理，停止 mitm 进程。

Lab4-2：开关前后各抓一趟，比对 Tracker / PII 是否仍传输 | Lab4-3：mitm 观测与 Frida 合并，判断运行时实际涉及哪些 PII

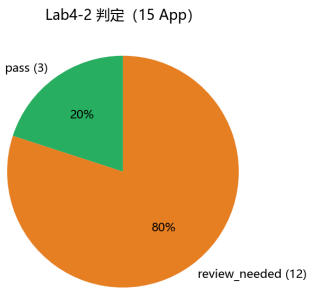
mitm 驱动的 Lab4-2 判定逻辑

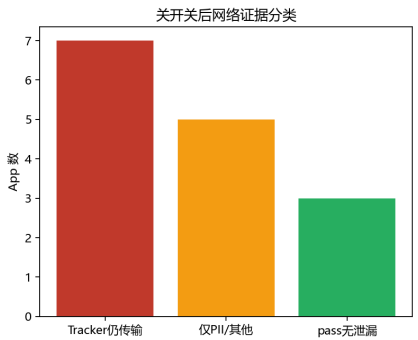
维度	含义	判定标签
Tracker	关隐私开关后 SDK 仍向追踪域名发包	`still_transmitting_after_off`
Tracker	开关有效，追踪传输停止	`tracker_stopped_after_off`
PII 网络字段	网络请求中 PII 字段不再出现	`pii_keys_stopped_after_off`
PII 网络字段	关开关后仍上传个人信息字段	`still_leaking_after_off`

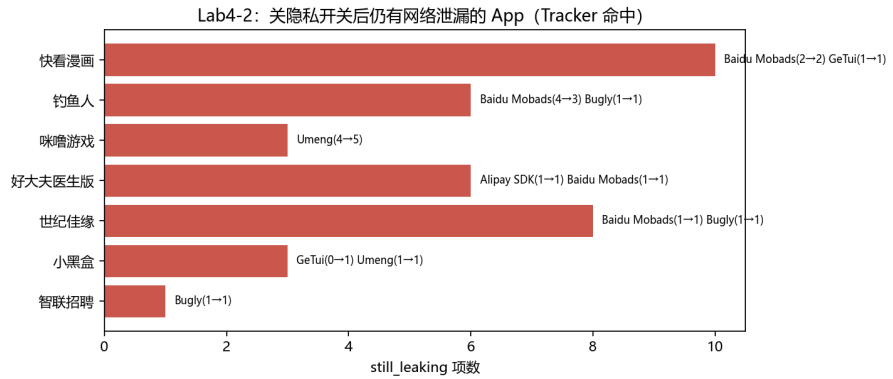
正面对照 — Keep：关后 `location/mac_address` 等 PII 命中 0；Tracker 无泄漏。

风险案例 — 钓鱼人：Umeng、Bugly、百度广告关后仍传（82→83 条流，6 个 Tracker 仍泄漏）。

mitm 实验结果（15 App • Lab4-2）





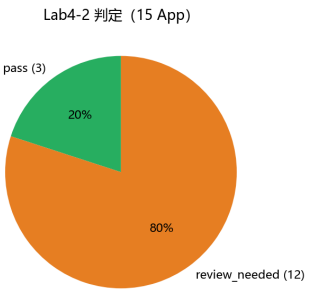


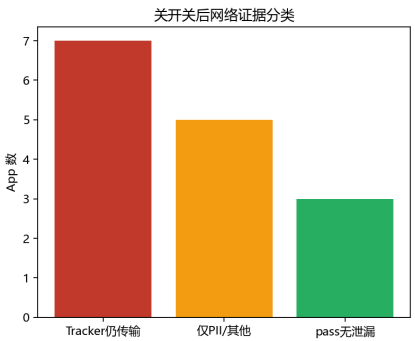
App	before 流	after 流	PII 命中	关后仍泄漏
小荷健康	272	312	58→58	无 SDK Tracker；仍有 PII 传输
快看漫画	162	206	21→17	SDK Tracker（Umeng/百度/个推）
世纪佳缘	234	276	38→38	SDK Tracker（百度/Bugly）
钓鱼人	82	83	30→33	SDK Tracker（Umeng/Bugly/百度）
Keep	67	1	4→0	**否（pass）**

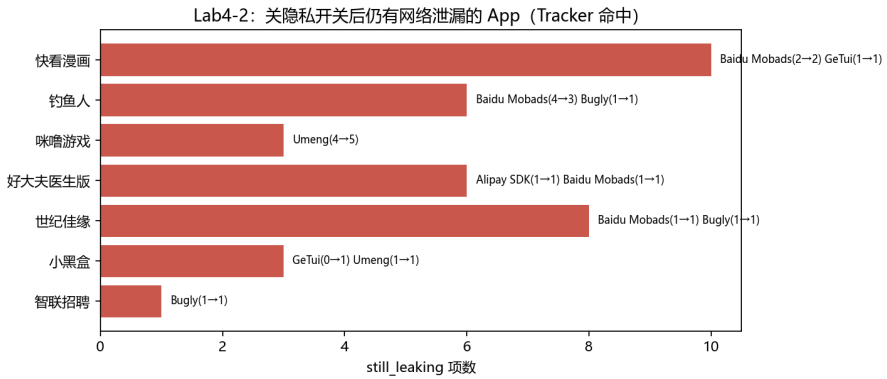
mitm 在 Lab4-3 中的角色

- **运行时观测合并**：primary_source 多为 mitm+frida
  - Frida：API 级（如 clipboard、contact_list）+ stack_summary
  - mitm：离设备传输级（如 account_info、biometric_info 出现在请求体）
- **污点完整性**：判断「采集到的 PII 是否经网络上送」—副本未含字段但 mitm 已命中 → 访问权/透明度风险
- **局限**：证书痂皮 App 流量不入 mitm；HTTPS 解密依赖模拟器用户证书信任

Lab4-2 本批结果（15 App）

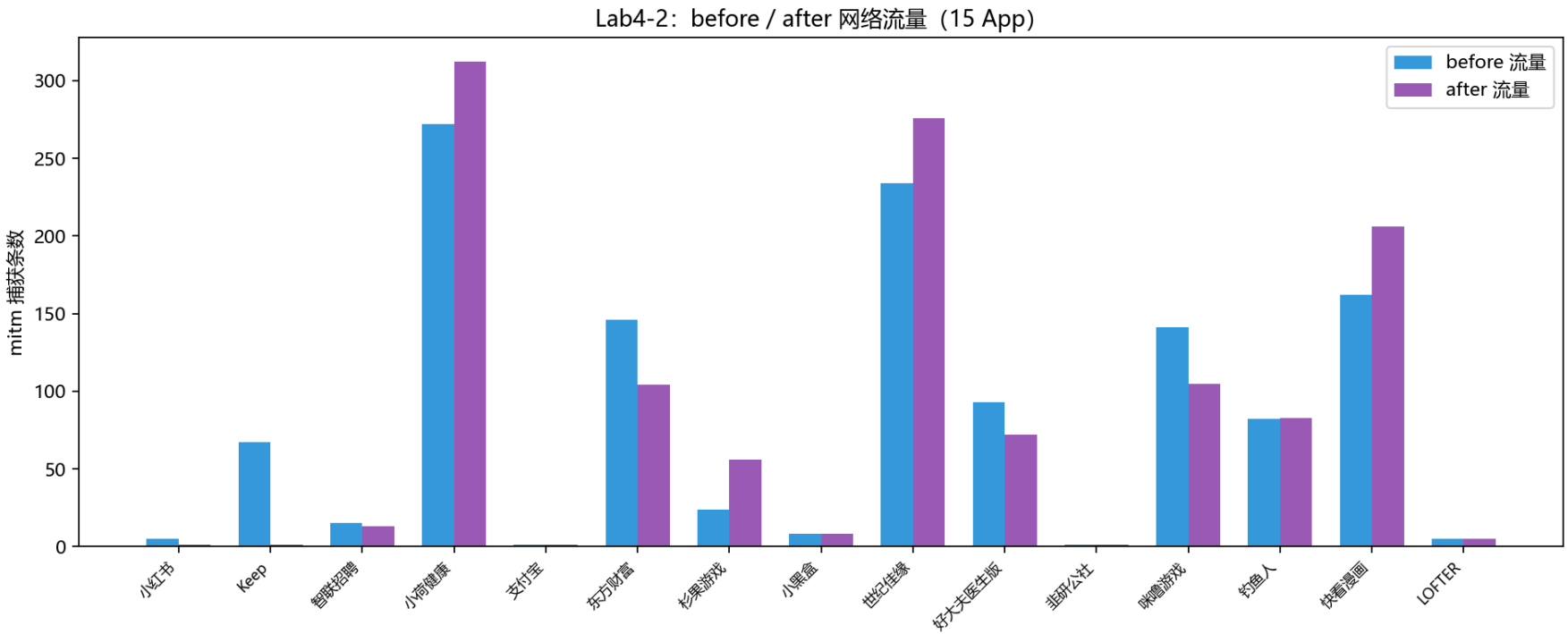






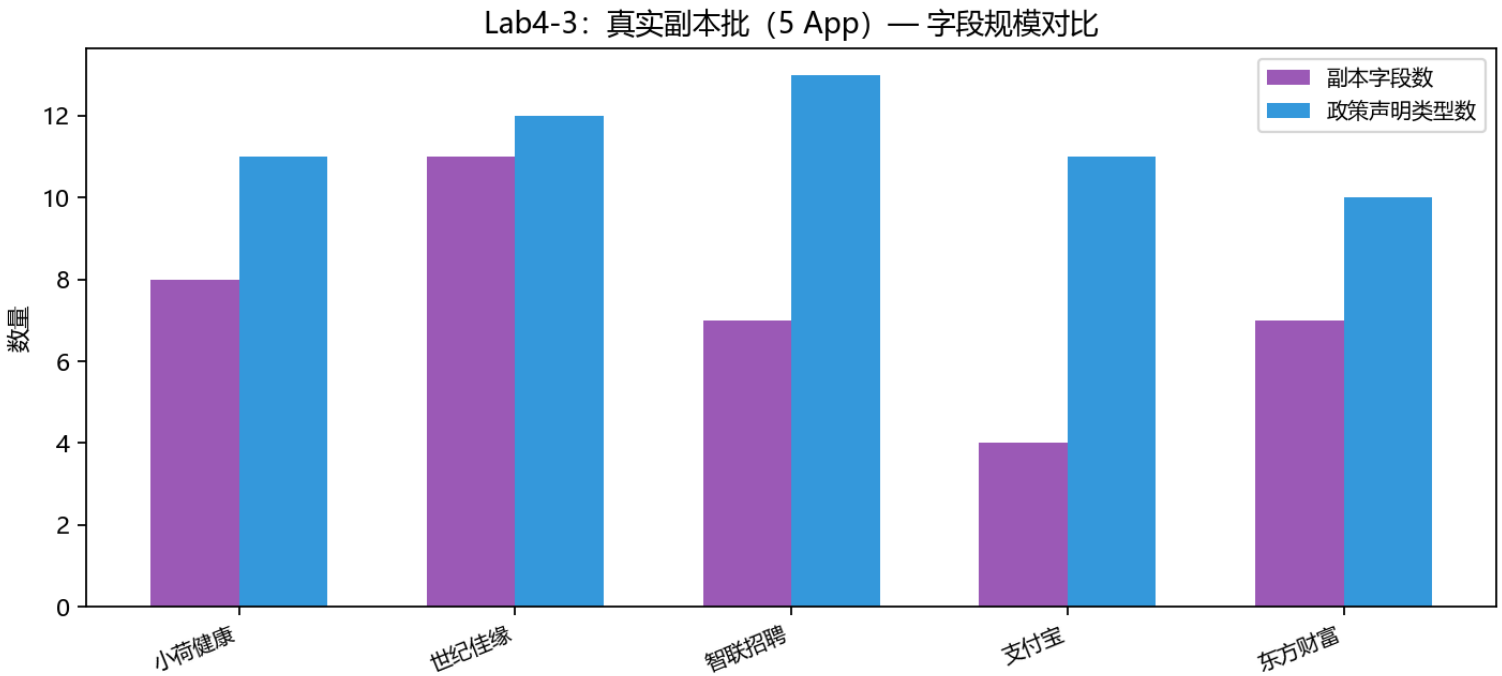
pass：Keep、支付宝、韭研公社 | 强案例：钓鱼人、好大夫、快看漫画、世纪佳缘

Lab4-2 网络流量 before/after



Lab4-3 人工审核结果（访问权）

App	副本所含个人信息类型
世纪佳缘	生物识别信息、手机号、账号/账户信息、身份信息
小荷健康	手机号、账号/账户信息、身份信息
智联招聘	手机号、身份信息、账号/账户信息、位置信息
支付宝	手机号、身份信息
东方财富	手机号、账号/账户信息、身份信息



动态验证手段分工

手段	强项	本批角色
Appium UI	政策路径导航、截图、关键词探测	**主轨**：驱动隐私设置页到达
mitm 网络	全进程 HTTP 污点、Tracker 识别、开关前后对比	**主轨**：Lab4-2/3 核心判定（`track3_network`）
Frida Hook	API 级采集、调用栈、IMEI 精准 Hook	**辅助**：tier1 App 补 API 证据；受 Spawn/Attach 限制
静态 + KB	APK 信号、法律知识库推断	Lab4-1 知情权多源合并

后续工作

- **Frida**：借鉴 frida-tools spawn gating；扩展 tier 探针（probe_hook.py）；加固 PAPI api_targets
- **mitm**：低流量 App 加长抓包窗口；证书钉扎绕过策略；补全 Lab4-3 剩余 6 款副本
- **UI**：支付宝 H5 容器 WebView context / OCR 辅助
- **taxonomy**：扩充副本字段别名，提升 Lab4-3 自动 coverage_rate

感谢聆听